📘 Chapter 5 – Reconnaissance, OSINT, Google Dorking & Shodan

🕵️ Introduction to Reconnaissance

📘 What is Reconnaissance?

Reconnaissance is the first phase of ethical hacking.

It means:

🔍 Information Gathering About the Target

Before attacking any system, hackers first collect as much information as possible.

🎯 Why Information Gathering is Important?

Because information helps attackers:

✅ Identify weaknesses
✅ Understand target infrastructure
✅ Find exposed services
✅ Discover emails and subdomains
✅ Prepare future attacks

🧠 Daily Life Example

Imagine a thief wants to rob a house.

Before robbery, he checks:

- Who lives there
- Security cameras
- Entry points
- Guard timings

- Neighbors

Similarly, ethical hackers first gather information before testing security.

🏢 Company Information Gathering

When performing reconnaissance on a company or website, hackers collect information like:

Information Type	Purpose
Website Name	Identify target
Founder Name	Social engineering
Contact Details	Communication paths
Email Addresses	Phishing targets
Public IP Address	Network targeting
Server Information	Identify technologies
Mail Server	Email infrastructure
Name Servers	DNS infrastructure

🌐 WHOIS Lookup

📘 What is WHOIS?

WHOIS is a protocol/service used to gather domain registration information.

🌍 Website

[WHOIS Lookup]

🎯 Why Ethical Hackers Use WHOIS?

WHOIS helps collect:

✅ Domain owner details
✅ Registrar information
✅ DNS details
✅ Contact emails
✅ Expiration dates
✅ Hosting-related information

🧩 Example

If you search:

example.com

on WHOIS, you may find:

- Domain registration date
- Expiry date
- Name servers
- Owner contact info
- Registrar company

📌 Information Available in WHOIS

🌐 Domain Information

Contains:

- Domain name
- Registered date
- Updated date
- Expiry date

- Name servers

🏢 Registrar Information

Contains:

- Registrar company
- IANA ID
- Abuse email
- Abuse phone number

👤 Registrant Contact

Contains domain buyer information like:

- Name
- Address
- City
- Country
- Postal code
- Phone number
- Email address

🛠️ Administrative & Technical Contacts

Contains contact details of:

- Domain administrators
- Technical teams

⚠️ Security Note

Modern WHOIS privacy protection may hide sensitive data.

🌐 NSLOOKUP Command

📘 What is NSLOOKUP?

NSLOOKUP is a DNS query tool.

Used to retrieve:

- IP addresses
- DNS records
- Mail server information
- Name server details

🔎 Finding Name Servers

✅ Syntax

nslookup example.com

🧩 Example

nslookup google.com

Shows:

- Public IP
- DNS server info

📧 Finding Mail Server (MX Records)

✅ Syntax

nslookup -type=mx example.com

🧩 Example

nslookup -type=mx gmail.com

📘 What are MX Records?

MX = Mail Exchange Records

They define:

📬 **Which servers handle emails for a domain.**

🧠 Why Attackers Check Mail Servers?

To identify:

- Email infrastructure
- Misconfigured mail servers
- Phishing targets

🌐 DIG Command

📘 What is DIG?

DIG = Domain Information Groper

Advanced DNS lookup tool used in Linux.

🎯 Why DIG is Used?

DIG helps retrieve:

✅ IP addresses
✅ DNS records
✅ MX records
✅ ASN information
✅ Name servers

🧩 Basic Example

dig google.com

📧 Mail Server Example

dig mx hummingbyte.com

Shows mail server details.

🌍 Public IP Discovery Using Ping

📘 Ping Command

Used to send ICMP packets to target.

🧩 Example

ping google.com

📌 What Happens?

The target replies with packets and reveals:

✅ Public IP address
✅ Connectivity status
✅ Response time

🌐 Traceroute Command

📘 Purpose

Shows network path between source and destination.

🧩 Linux Example

traceroute google.com

🧩 Windows Equivalent

tracert google.com

🎯 Why Traceroute is Useful?

Helps identify:

- Routing path
- ISP hops
- Delays
- Intermediate devices

🛠️ theHarvester Tool

📘 What is theHarvester?

theHarvester is an OSINT (Open Source Intelligence) tool used for information gathering.

🎯 What Can It Find?

✅ Email addresses
✅ Subdomains
✅ Hosts
✅ Employee information
✅ Publicly available data

🧩 Example Command

theHarvester -d codingseekho.in -b bing

📘 Command Breakdown

Option	Meaning
-d	Target domain
-b	Data source
bing	Bing search engine source

📌 What It Does?

Searches Bing for:

- Emails related to domain
- Subdomains
- Public information

🧠 Daily Life Example

Suppose a company has:

admin@company.com
support@company.com
mail.company.com
dev.company.com

theHarvester may discover these publicly exposed details.

🛠️ recon-ng Framework

📘 What is recon-ng?

Recon-ng is a reconnaissance framework used for automated information gathering.

It works somewhat like:

🧰 Metasploit for Reconnaissance

🎯 Features

- ✅ Modular framework
- ✅ Domain reconnaissance
- ✅ Email gathering
- ✅ Subdomain enumeration
- ✅ WHOIS lookup
- ✅ API integration

🧩 Step-by-Step Workflow

📁 Create Workspace

workspaces create tesla

Creates a workspace folder.

📂 Select Workspace

workspaces select tesla

🔎 Search Available Modules

modules search

Displays available reconnaissance modules.

📦 Load WHOIS Module

modules load recon/domains-contacts/whois_pocs

🎯 Set Target Domain

options set SOURCE tesla.com

▶️ Run Module

run

📨 What Happens?

If recon-ng has data available, it may return:

- Email addresses
- Domain contacts
- WHOIS information

🌐 Host Enumeration Module

Load Module

modules load recon/domains-hosts/hackertarget

Set Target

options set SOURCE codingseekho.in

Run

run

📘 Output May Include

✅ Subdomains
✅ IP addresses
✅ Hosts

🎯 Why Subdomains Are Important?

One domain may contain many subdomains like:

mail.example.com
dev.example.com
admin.example.com
vpn.example.com

Some subdomains may have vulnerabilities.

🔍 Google Dorking

📘 What is Google Dorking?

Google Dorking means using advanced Google search operators to find sensitive or hidden information.

🎯 Ethical Hackers Use It To Find

✅ Exposed documents
✅ Login pages
✅ Emails
✅ Backup files
✅ Configuration files
✅ Security vulnerabilities

⚠️ Important Legal Note

Google Dorking must only be used for:

✅ Authorized security testing
✅ OSINT research

Unauthorized misuse can be illegal.

🔎 Common Google Dork Operators

Operator	Purpose
site:	Search inside specific domain
filetype:	Search specific file types
intitle:	Search page title
inurl:	Search in URL
intext:	Search inside page content
ext:	File extension search
cache:	View cached page
link:	Pages linking to target
related:	Similar websites
allintitle:	All words in title
allinurl:	All words in URL

🧩 Google Dork Examples

🔐 Find Login Pages

intitle:login

or

inurl:admin login

📄 Find PDF Files

site:example.com filetype:pdf confidential

📊 Find Excel Files

filetype:xls site:gov.in

📁 View Open Directory Listings

intitle:index.of

🔑 Find Password Files

intext:password filetype:txt

📧 Find Emails

site:example.com intext:@example.com

💾 Find Backup Files

intitle:index.of backup

or

ext:bak

🗄️ Find Database Dumps

filetype:sql intext:"insert into"

🌐 Find WordPress Login

inurl:wp-login.php

📘 Example Breakdown

site:example.com filetype:pdf confidential

📌 Meaning

Part	Meaning
site:example.com	Search only this website
filetype:pdf	Show PDF files only
confidential	Must contain word confidential

💡 Tips for Google Dorking

✅ Use quotes " " for exact matches
✅ Combine operators
✅ Use OR for alternatives
✅ Use - to exclude terms

🧩 Example

inurl:admin OR login

📚 Google Hacking Database (GHDB)

Google maintains many public dork queries.

🌍 Website

Exploit-DB Google Hacking Database

📘 Shortcut Name

🔥 GHDB

(Google Hacking Database)

🌐 Shodan Search Engine

📘 What is Shodan?

Shodan is a search engine for internet-connected devices.

📘 Full Form

🌐 Sentient Hyper-Optimized Data Access Network

🎯 What Shodan Can Find?

Shodan scans the internet and indexes:

✅ Servers
✅ CCTV cameras
✅ Routers
✅ IoT devices
✅ Open ports
✅ Web servers
✅ Databases
✅ Firewalls

⚠️ Important Concept

Shodan itself scans devices.

You only search the indexed data.

🔐 Login Requirement

You must create/login to an account before using many features.

🧩 Shodan Search Format

<search term> filter:value

📋 Common Shodan Filters

Filter	Purpose
ip:	Specific IP
hostname:	Specific hostname
port:	Search by port
country:	Country code
city:	City
org:	Organization
asn:	Autonomous System Number
os:	Operating system
product:	Product/service name
version:	Software version
before:	Before specific date

Filter	Purpose
after:	After specific date
ssl:	SSL certificate details
vuln:	Search CVEs
title:	Website title
net:	CIDR network range

🧩 Shodan Examples

📡 Find SSH Services in India

port:22 country:IN

🌐 Find Apache Servers in USA

product:Apache country:US

🗄️ Find Open MySQL Databases

port:3306

🔐 Find Expired SSL Certificates

ssl:expired:true

🚨 Search Vulnerable Devices

vuln:CVE-2021-26855

🪟 Find Windows Devices

os:"Windows" port:445

📼 CCTV / DVR Search

title:"DVR login"

🎥 Webcam Search

title:"webcamXP"

🧠 Bonus Shodan Tips

📌 Combine Filters

port:22 os:"Linux" country:IN

📌 Multi-word Search

product:"Apache Tomcat"

⚠️ Legal & Ethical Warning

Reconnaissance tools are powerful.

Always remember:

❌ Unauthorized scanning is illegal
❌ Attacking exposed systems without permission is cybercrime

Use these tools only for:

✅ Ethical hacking labs
✅ Authorized penetration testing
✅ Security research
✅ OSINT investigations

🧠 Quick Revision Table

Tool/Command	Purpose
whois.com	Domain information
nslookup	DNS lookup
dig	Advanced DNS lookup
ping	Connectivity & IP
traceroute	Network path
theHarvester	Emails & subdomains
recon-ng	Automated reconnaissance
Google Dorking	Advanced Google searches
Shodan	Internet-connected device search
